Методы и принципы проектирования современных защищённых систем

Лекция 3

Обнаружение атак по журналу событий

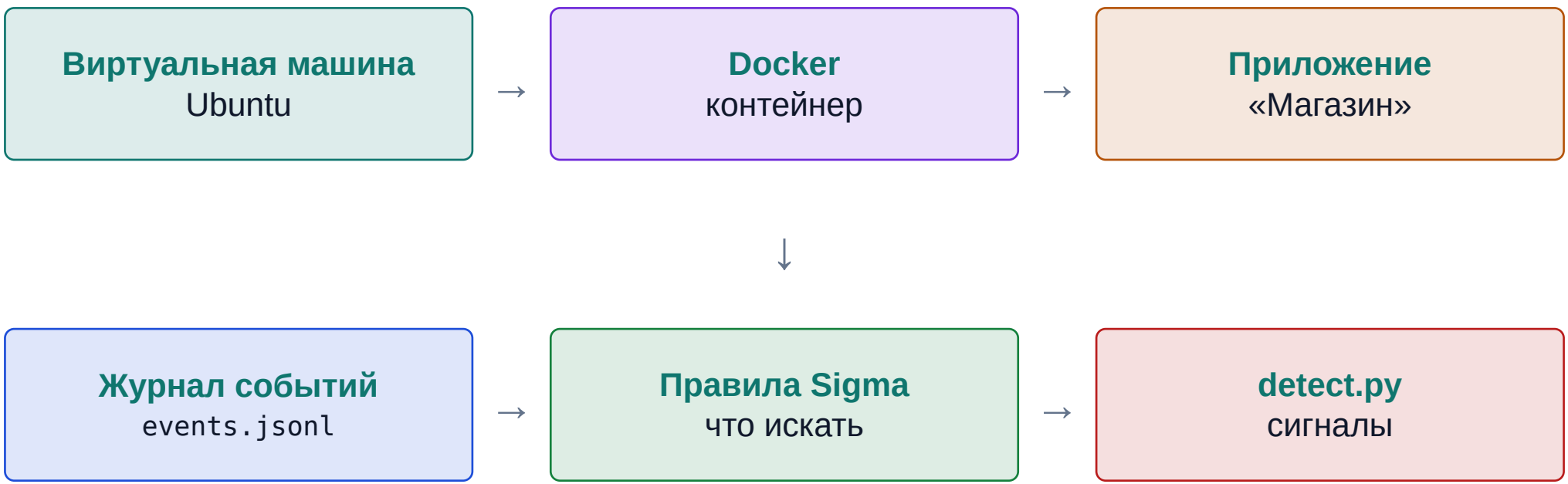
Интерактивная практика · атака в браузере, живой журнал, правила Sigma

Что сделаем за занятие

1. Создать виртуальную машину Ubuntu
2. Посмотреть журналы системы
3. Развернуть приложение в Docker
4. Увидеть журнал событий приложения
5. Написать первое правило Sigma
6. Провести атаку и обнаружить её
7. Убрать ложное срабатывание

\+ Обнаружить перебор чужих заказов

Схема стенда



Действия пользователей и нарушителя → журнал → правила → сигналы

TraceShop LAB: четыре задачи в браузере

01 · Подбор
5 неудач для `anna`, затем успешный вход

02 · Распыление
1 пароль, 8 разных логинов, 1 IP-адрес

03 · Перебор заказов
начать с 1001 и накопить 5 отказов

04 · Отключение MFA
оставить заявку пустой и создать критичное событие

Порядок фиксирован: каждая задача открывает следующую, а прогресс совпадает с порогами Sigma

ПРАКТИКА 3 · RED TEAM → BLUE TEAM

Взломайте учебный магазин.

Затем поймайте себя по журналу.

Все действия настоящие: запросы уходят в приложение, а события появляются справа в реальном времени. Выполняйте миссии строго слева направо — следующая откроется после предыдущей.

ПЕРЕХВАЧЕННАЯ ЗАМЕТКА

Покупатель anna любит цветы. В конце пароля — одна цифра.

Номера заказов последовательны и начинаются с 1001.

Адрес исследователя 203.0.113.77

01 Получить доступ как anna
0/5 неудач, затем успех

02 Создать распыление
заблокировано

03 Найти чужие заказы
заблокировано

04 Отключить MFA без заявки
заблокировано

АТАКУЮЩАЯ СТОРОНА

РУЧНОЙ РЕЖИМ

Рабочая консоль

ЗАЩИТНАЯ СТОРОНА

ОБНОВЛЕНИЕ 2 СЕК

Живая телеметрия

Задача 01 · получить доступ как anna

Сначала создать след
5 неверных паролей
для `anna`

→

Затем войти
верный пароль
`sunflower7`

> Успех до пяти отказов не завершает задачу: важна последовательность «неудачи → вход»

T TraceShop LAB

журнал активен | Сбросить стенд

01 Получить доступ как anna
выполнено ✓

02 Создать распыление
0/8 разных логинов

03 Найти чужие заказы
заблокировано

04 Отключить MFA без заявки
заблокировано

АТАКУЮЩАЯ СТОРОНА

РУЧНОЙ РЕЖИМ

Рабочая консоль

01 Подбор пароля

Проверяйте гипотезы по одной и следите за событиями.

УЧЁТНАЯ ЗАПИСЬ: anna

ПАРОЛЬ: sunflower7

123456 | qwerty | anna2026 | sunflower | letmein

Попробовать войти

МИССИЯ ВЫПОЛНЕНА · доступ как anna

02 Распыление пароля

Один пароль, разные логины, один адрес.

ОДИН ПАРОЛЬ: 123456

СЛЕДУЮЩАЯ УЧЁТНАЯ ЗАПИСЬ: clara

АДРЕС ИСТОЧНИКА: 198.51.100.23

Отправить попытку

Нужно 8 разных логинов

ЗАЩИТНАЯ СТОРОНА

ОБНОВЛЕНИЕ 2 СЕК

Живая телеметрия

6	5	0
событий	ошибок входа	отказов доступа

НАБЛЮДЕНИЕ

anna: 5 неудач

Последние события — обновить

auth.login · success 12:39:23
actor=anna source=203.0.113.77

auth.login · failure 12:39:22
actor=anna source=203.0.113.77

auth.login · failure 12:39:22
actor=anna source=203.0.113.77

auth.login · failure 12:39:22
actor=anna source=203.0.113.77

auth.login · failure 12:39:22
actor=anna source=203.0.113.77

Задача 02 · создать распыление

1 · Один пароль

`123456` остаётся неизменным

2 · Разные логины

восемь разных учётных записей

3 · Один адрес

`198.51.100.23` связывает попытки

Группировка по адресу раскрывает кампанию из многих тихих попыток

01 Получить доступ как anna
выполнено ✓

02 Создать распыление
выполнено ✓

03 Найти чужие заказы
0/5 отказов

04 Отключить MFA без заявки
заблокировано

АТАКУЮЩАЯ СТОРОНА

РУЧНОЙ РЕЖИМ

Рабочая консоль

01 Подбор пароля

Проверяйте гипотезы по одной и следите за событиями.

УЧЁТНАЯ ЗАПИСЬ: anna

ПАРОЛЬ: sunflower7

123456 qwerty anna2026 sunflower letmein

Попробовать войти

МИССИЯ ВЫПОЛНЕНА · доступ как anna

02 Распыление пароля

Один пароль, разные логины, один адрес.

ОДИН ПАРОЛЬ: 123456

СЛЕДУЮЩАЯ УЧЁТНАЯ ЗАПИСЬ: kirill

АДРЕС ИСТОЧНИКА: 198.51.100.23

Отправить попытку

Попытка записана · kirill · 8/8 разных логинов

ЗАЩИТНАЯ СТОРОНА

ОБНОВЛЕНИЕ 2 СЕК

Живая телеметрия

14	13	0
событий	ошибок входа	отказов доступа

НАБЛЮДЕНИЕ

anna: 5 неудач · распыление: 198.51.100.23

Последние события — обновить

```
auth.login · failure 12:39:25
actor=kirill source=198.51.100.23

auth.login · failure 12:39:25
actor=julia source=198.51.100.23

auth.login · failure 12:39:24
actor=igor source=198.51.100.23

auth.login · failure 12:39:24
actor=galina source=198.51.100.23

auth.login · failure 12:39:24
actor=frank source=198.51.100.23
```

Задача 03 · найти чужие заказы

Свои заказы

1001–1002 принадлежат `anna` — `data.read · success`

Чужие заказы

1003–1007 чужие — `authz.access · failure`, причина `not_owner`

Цель

накопить 5 отказов перебором номеров

> Журнал сохраняет, кто обращался, к какому объекту и почему отказано

123456 qwerty anna2026 sunflower letmein

Попробовать войти

МИССИЯ ВЫПОЛНЕНА · доступ как anna

02 Распыление пароля

Один пароль, разные логины, один адрес.

ОДИН ПАРОЛЬ: 123456

СЛЕДУЮЩАЯ УЧЁТНАЯ ЗАПИСЬ: kirill

АДРЕС ИСТОЧНИКА: 198.51.100.23

Отправить попытку

Попытка записана · kirill · 8/8 разных логинов

03 Перебор заказов

Проверяйте соседние ID.

ДЕЙСТВОВАТЬ КАК: anna

НОМЕР ЗАКАЗА: 1007

Открыть заказ

403 · not_owner · отказов 5/5

04 Отключение MFA

Оставьте заявку пустой.

ДЕЙСТВОВАТЬ КАК: anna

ID ЗАЯВКИ (НЕОБЯЗАТЕЛЬНО): например, SEC-42

Отключить MFA

Повторный пароль не требуется

anna: 5 неудач · распыление: 198.51.100.23 · отказы anna: 5

Последние события

обновить

authz.access · failure 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

data.read · success 12:39:26
actor=anna source=203.0.113.77

data.read · success 12:39:26
actor=anna source=203.0.113.77

auth.login · failure 12:39:25
actor=kirill source=198.51.100.23

auth.login · failure 12:39:25
actor=julia source=198.51.100.23

auth.login · failure 12:39:24
actor=igor source=198.51.100.23

Задача 04 · отключить MFA

Уязвимость

второй фактор отключается без повторного ввода пароля

След в журнале

`auth.mfa.disable` без поля `ticket_id`

Важность

событие уровня `high` — критичное действие

Четыре задачи выполнены — в журнале видна вся цепочка атаки

123456 qwerty anna2026 sunflower letmein

Попробовать войти

МИССИЯ ВЫПОЛНЕНА · доступ как anna

02 Распыление пароля

Один пароль, разные логины, один адрес.

ОДИН ПАРОЛЬ: 123456

СЛЕДУЮЩАЯ УЧЁТНАЯ ЗАПИСЬ: kirill

АДРЕС ИСТОЧНИКА: 198.51.100.23

Отправить попытку

Попытка записана · kirill · 8/8 разных логинов

03 Перебор заказов

Проверяйте соседние ID.

ДЕЙСТВОВАТЬ КАК: anna

НОМЕР ЗАКАЗА: 1007

Открыть заказ

403 · not_owner · отказов 5/5

04 Отключение MFA

Оставьте заявку пустой.

ДЕЙСТВОВАТЬ КАК: anna

ID ЗАЯВКИ (НЕОБЯЗАТЕЛЬНО): например, SEC-42

Отключить MFA

MFA отключён · anna

заявки: 1

Последние события

обновить

auth.mfa.disable · success 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:27
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

authz.access · failure 12:39:26
actor=anna source=203.0.113.77

data.read · success 12:39:26
actor=anna source=203.0.113.77

data.read · success 12:39:26
actor=anna source=203.0.113.77

auth.login · failure 12:39:25
actor=kirill source=198.51.100.23

auth.login · failure 12:39:25
actor=julia source=198.51.100.23

Событие в журнале отвечает на вопросы

Что произошло?	`"event_type": "auth.login"`
Чем закончилось?	`"outcome": "failure"`
Кто?	`"actor": {"id": "anna"}`
Откуда?	`"source_ip": "203.0.113.77"`
Подробности?	`"context": {"reason": "bad_password"}`

Единый формат → одно правило находит все такие события

Правило — условие над записями журнала

Базовые правила, на которые ссылаются корреляции (`00_base.yml`):

```yaml
title: Неудачный вход
name: failed_login
logsource: {product: shop-app, service: auth}
detection:
    selection: {event_type: auth.login, outcome: failure}
    condition: selection
---
title: Успешный вход
name: successful_login
detection:
    selection: {event_type: auth.login, outcome: success}
    condition: selection
```

Правило: подбор пароля

```
title: Подбор пароля к учётной записи
correlation:
    type: event_count
    rules: [failed_login]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 5}
```

event_count считаем события

group-by по учётной записи

condition 5 и более неудач за 10 минут

Правило: распыление паролей

```
title: Распыление паролей с одного адреса
correlation:
    type: value_count
    rules: [failed_login]
    group-by: [source_ip]
    timespan: 30m
    condition: {field: actor.id, gte: 8}
```

value_count считаем РАЗНЫЕ значения

group-by по адресу источника

condition 8 и более разных учётных записей

Правило: вход после серии неудач

```yaml
title: Успешный вход после серии неудач
correlation:
    type: temporal_ordered
    rules: [failed_login_burst, successful_login]
    group-by: [actor.id]
    timespan: 15m
---
name: failed_login_burst
correlation:
    type: event_count
    rules: [failed_login]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 3}
```

`temporal_ordered` события в заданном порядке

сначала серия неудач, затем успешный вход

Запуск: `python3 detect.py --events ../app/logs/events.jsonl --rules rules`

Дополнительное задание

Атака
нарушитель под `anna`
перебирает чужие заказы

→

След
`authz.access`
`outcome: failure`

> Напишите правило `event_count` по `actor.id` для отказов в доступе. Сколько отказов у `anna`?

Решение дополнительного задания

```yaml
title: Перебор чужих объектов
name: object_enumeration
detection:
    selection:
        event_type: authz.access
        outcome: failure
    condition: selection
---
title: Серия отказов в доступе
correlation:
    type: event_count
    rules: [object_enumeration]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 5}
```

1 сигнал

учётная запись anna
7 отказов в доступе

Методы и принципы проектирования современных защищённых систем

Лекция 3

Обнаружение атак по журналу событий

Интерактивная практика · атака в браузере, живой журнал, правила Sigma